SecARS - M2 Functional Tests

Format per SR14: expected result, actual result, date and tester are recorded for every test.

Run against a local stack: Oracle FREEPDB1, Spring Boot on `localhost:8080`, React on `localhost:5173`.

Demo accounts (passwords are set with `hashgen`, never stored in Git):

Username	Role	Password used in tests
student1	STUDENT	StudentDemo2026
lecturer1	LECTURER	LecturerDemo2026
registrar1	REGISTRAR	RegistrarDemo2026
registrar2	REGISTRAR (second approver)	RegistrarDemo2026
auditor1	AUDITOR	AuditorDemo2026

Test data: the seed (`db/03_seed.sql`) gives 20 OPEN, 10 SUBMITTED and 10 PUBLISHED sections for term 2026-1.

Tests that change data assume a fresh seed, or use a section whose state the test itself sets.

A. Authentication (FR01, BR12, BR13)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T01	Database health	GET `/api/health/db`	200 `{"database":"UP"}`				
T02	Successful login	Sign in as student1 with the correct password	Redirect to `/student`; `/api/auth/me` returns `ROLE_STUDENT`				
T03	Generic failure (FR09)	Sign in with a wrong password	Message "Invalid username or password"; no detail about which part was wrong				
T04	Lock-out (BR12)	Five wrong passwords, then the correct one	The sixth attempt is refused (401); `security_events` has `ACCOUNT_LOCKED`				
T05	Logout	Sign out, then call `/api/auth/me`	Logout returns 204; `/me` returns 401				
T06	CSRF on changing requests	PUT `/api/lecturer/enrollments/1/grade` with no CSRF header, after login as lecturer1	403				

B. Student (FR02, BR06, BR07)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T07	Own courses only	Sign in as student1 and open `/student`	Only enrolments of student1 are listed (no other student's rows)				
T08	Grades hidden until published (BR06)	Same page, for sections that are not PUBLISHED	Grade column shows "Not published"				
T09	Grade shown after publishing	After T19 publishes a section, reload `/student`	The grade of student1 in that section is shown				

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T10	Role boundary	Sign in as student1, call GET `/api/lecturer/offerings`	403 (role check in SecurityConfig)				

C. Lecturer (FR03, FR04, BR02, BR03, BR04)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T11	Own sections only (FR03)	Sign in as lecturer1 and open `/lecturer`	Only sections taught by lecturer1 are listed				
T12	Access to another lecturer's section refused (FR03)	Call GET `/api/lecturer/offerings/{id}/grades` with an offering id that belongs to another lecturer	403 "Not allowed"; `security_events` has `ACCESS_DENIED`				
T13	Grade entry (FR04)	Enter 88 for a student in an OPEN section and press Save	Saved message; `grade_audit` has an `ENTRY` or `EDIT` row for that enrolment				
T14	Grade range (BR01)	Call PUT with grade 101	400 "Grade must be between 0 and 100"				
T15	Edit history (FR04)	Change an existing grade (e.g. 85.66 to 88)	Auditor-visible audit row `EDIT` with old and new value (checked in T26)				
T16	Closed section is read-only (BR03, BR04)	Call PUT on a SUBMITTED section	400 "Section is closed. Grade changes need an approved request."				
T17	Submit moves forward only (BR02)	Submit an OPEN section; submit it again	First call 204 and status SUBMITTED; second call 400 "Only open sections can be submitted"				

D. Registrar (FR05 part, FR06, BR02, BR05)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T18	Publish only submitted sections (BR02)	Publish an OPEN section	400 "Only submitted sections can be published"				
T19	Publish (BR02)	Publish a SUBMITTED section (e.g. CSC122)	Status PUBLISHED				
T20	Reason length (BR04)	Request a change with a 5-character reason	400 "Reason must be at least 10 characters"				
T21	Post-close only (BR04)	Request a change on an OPEN section	400 "Section is still open..."				
T22	Request a change (FR06)	Request a change on a SUBMITTED section with a valid reason (CSC122, Jana Rashid, 60.32 to 70)	Request appears in pending list as PENDING; grade unchanged				
T23	Self-approval refused (BR05, SR08)	As registrar1, press Approve on its own request	403 "Not allowed"; `security_events` has `ACCESS_DENIED`				
T24	Four-eyes approval (FR06)	As registrar2, press Approve on the request from T22	Grade becomes 70; request status APPROVED; `grade_audit` has `POST_CLOSE` with the reason and request id				
T25	Decide once only	Call the decision endpoint again for the same request	400 "This request was already decided"				

E. Auditor (FR07, BR14)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T26	Grade history visible	Sign in as auditor1 and open the Grade history tab	Rows for ENTRY, EDIT and POST_CLOSE appear with actor, role, old and new value				
T27	Security events visible	Open the Security events tab	LOGIN, LOGIN_FAILED, ACCOUNT_LOCKED and ACCESS_DENIED rows appear				
T28	Read only	Call POST `/api/registrar/change-requests` as auditor1	403				
T29	Auditor cannot read as another role	Call GET `/api/student/enrollments` as auditor1	403				

F. Error handling (FR09)

ID	Requirement	Steps	Expected result	Actual	Result	Date	Tester
T30	No internal details to the client	Stop the Oracle listener, then call any data endpoint as a signed-in user	Response: "Something went wrong" with a correlationId only; the ORA code and stack trace appear only in the server log under the same id				

Known limits (not tested in M2)

- Session idle timeout (15 minutes) is set in configuration; it is not automated.
- VPD, Unified Auditing, encryption and masking belong to M3 and M4.
- Admin screens for adding students, courses and sections (FR05 full scope) are not built yet.